

Secure RAG Checklist

Poisoning, permission bypass, and cross-user leakage — what to verify

Retrieval-Augmented Generation lets an agent answer from your documents — which means your document store is now part of the attack surface. Three things go wrong: **poisoning** (a malicious document steers the answer), **permission bypass** (the agent retrieves documents the user isn't allowed to see), and **cross-user leakage** (one tenant's data surfaces in another's answer). RAG is also an indirect prompt-injection surface — a retrieved document can carry instructions.

What to verify

Area	The review question
Document permissions	Does retrieval enforce the user's access rights at query time — not just at ingestion? Can the agent surface a restricted document?
Source trust	Are retrieval sources vetted? Can an untrusted party add documents to the index (the poisoning path)?
Cross-user isolation	In multi-tenant use, is retrieval scoped so one user's data never appears in another's context?
Sensitive documents	Are restricted / regulated documents excluded or masked? Is PII in chunks controlled?
Citation integrity	Does the agent cite its sources so answers are traceable and a poisoned source is spottable?
Injection from content	Is retrieved text treated as data, not instructions? (see Playbook 02, indirect injection)
Logging	Are retrievals logged — which documents fed which answer — for audit and IR?

How to test (authorized lab only)

Use a test corpus with safe, synthetic documents — never real regulated data.

Probe	What you are checking
Permission probe	As a low-privilege test user, ask for content only a higher-privilege user should see.
Poisoning probe	Insert a benign "poison" document with a planted claim; ask a question and see if it dominates.
Leakage probe	As tenant A, ask questions whose answers live only in tenant B's documents.
Citation probe	Verify every answer traces to a real retrieved source, not a fabrication.

Framework mapping

RAG weaknesses map to: **OWASP LLM08 (Vector & Embedding Weaknesses)**, **LLM01 (Prompt Injection)** for content-borne instructions, and **LLM02 (Sensitive Information Disclosure)** for leakage; **NIST AI RMF (Map, Measure)**; **ISO/IEC 42001**; and, where regulated data is involved, **GDPR**, **HIPAA**, or **CCPA** auto-triggered by the data types and user locations captured at intake.

Reviewer's quick checklist

- Retrieval enforces per-user permissions at query time, not just ingestion.
- Retrieval sources vetted; untrusted parties cannot add to the index.
- Multi-tenant retrieval scoped — no cross-user leakage.
- Restricted / regulated documents excluded or masked.
- Answers cite real retrieved sources; retrievals logged.
- Retrieved content treated as data, not instructions.
- Poisoning, permission, and leakage probes run on a synthetic corpus.

Safety. Use safe sample data only. Never use real credentials, tokens, or customer data, and never test production systems. Any dynamic probing runs only against an explicitly authorized lab or staging environment, and all results are labeled as authorized testing.